

Network interception, capture and analysis

Module 2 of 4

3 hours

Defensive Lab Agency | pts-project.org

Main objective

Capture and analyze the network traffic of a potentially compromised device using PiRogue, with real and simulated malicious devices.

You will learn to intercept, inspect and interpret network flows, identify indicators of compromise, and triage suspicious connections using PiRogue's built-in tooling.

Full write-up: [🔗 docs.pts-project.org/guides/capture-and-analyze-traffic](https://docs.pts-project.org/guides/capture-and-analyze-traffic)

Where we left case LAB-001

Module 1 recap:

- intake report: battery drain, data spikes, a "Wire secure update" installed from an SMS link
- case LAB-001 open in Colander, shared with the Analysts team
- PiRogue enrolled in the fleet, UP

Today, the "journalist's phone" (our wiped test device) goes on the wire. By the end of the module, we will have spotted the suspicious traffic and documented our first IOCs.

Agenda

1. Why analyze network traffic (15 min)
2. Network refresher (20 min)
3. How PiRogue intercepts traffic (20 min)
4. Live capture: dashboard, PCAP, export (30 min)
5. Suricata alerts: interpretation and triage (30 min)
6. Network DPI classification (20 min)
7. From traffic to IOCs, into Colander (25 min)
8. Exercise (20 min)

Main threats on mobile devices

- Phishing / Smishing
- Malware (generic)
- Adware
- Spyware
- Infostealer
- Stalkerware
- Counterfeit applications

Malicious apps arrive through phishing links, chat groups, shady websites, alternative stores, and sometimes remote exploitation. Our scenario started with a smishing link: the most common entry point by far.

Why intercept network traffic

- to measure how "talkative" a device is
- to discover the list of communications to remote servers
- to detect potentially malicious activities
- to save the traffic into a single file
- to get evidence of specific types of activity
- to conduct further analysis

Malware has to talk to its operators: to receive commands, to exfiltrate data, to confirm it is alive. The network is where it shows itself, even when it hides perfectly on the device.

Recommendations & precautions

When investigating a potentially compromised device:

- get **informed consent** from the device owner, and write it down in the case
- capture traffic for **several days** to maximize the chance to catch something: some implants beacon rarely or only on events
- you are potentially disclosing information about your organization (IP, location...): the C2 sees who is talking to it
- work on a **dedicated, isolated network**
- document everything: dates, device state, who handled it, what was done

If you are less confident with network analysis, ask for assistance. That is also what working with partner organizations is for.

Questions

What is the difference between a **DNS request** and an **HTTP request**?

Why can't we read the content of **HTTPS** traffic directly?

What is a **port**? Name two well-known ones.

Which of these can we still observe when traffic is encrypted?

Network refresher

- **DNS:** translates a domain name into an IP address. Even encrypted apps leak the domains they contact.
- **TCP/IP:** transport of data between the device and remote servers.
- **HTTPS (HTTP over TLS):** content is encrypted, but metadata remains visible: server name (SNI), IP address, timing, volume, certificate.
- **Common ports:** 53 DNS, 80 HTTP, 443 HTTPS. Malware often uses 443 to blend in, or odd ports like 8443 that stand out.

A lot of analysis is possible **without decrypting anything**: who, when, how often, how much.

How PiRogue intercepts traffic

The PiRogue sits between the device and the internet, acting as its gateway. All traffic flows through it.

Operating modes:

- **Access point:** the device joins the PiRogue's Wi-Fi network (physical PiRogue)
- **Appliance:** the device is plugged behind the PiRogue's second Ethernet port
- **VPN:** the device connects through WireGuard to a virtual PiRogue (covered in depth in module 3)

Same capture and analysis tooling in every mode.

What runs on the PiRogue

- **Suricata:** intrusion detection, raises alerts on known malicious patterns using rule sets updated regularly (sources managed in Admin Web)
- **NFStream:** deep packet inspection, classifies flows by protocol and application
- **mitmproxy:** TLS interception for in-depth app analysis (when needed and consented)
- **Mongoose:** collects network events and enriches them: direction, hostnames, Community ID, risk score, GeoIP (when enabled), then forwards them to Colander
- **Grafana:** real-time dashboard on top of the collected data

Connecting a target device

Physical PiRogue, access point mode:

1. power the PiRogue, wait for the access point to appear
2. get the Wi-Fi passphrase: `pirogue-admin-client wifi get-configuration`
3. connect the target device to the PiRogue Wi-Fi
4. verify it shows up in Admin Web → **Network** (connected devices)
5. traffic is captured and analyzed immediately

For a longer, remote analysis, create a **device monitoring** in Colander instead: 1 to 14 days, stops automatically (module 3).

Live demo, part 1

The journalist's phone goes on the wire

Live capture and export

To capture the raw traffic into a PCAP file, on the PiRogue:

```
sudo tcpdump -i wlan0 -w $(date +%Y%m%d%H%M)_capture.pcap # Ctrl+C to stop
```

`wlan0` = access point interface (other modes: `ip -br link`). Copy the file to your computer with `scp`, open it in Wireshark.

The PCAP is your **evidence**: hash it immediately, keep the original untouched, work on copies:

```
sha256sum <timestamp>_capture.pcap
```

The hash goes into the case notes: it proves, months later, that the file was not altered.

The Grafana dashboard

`https://<your PiRogue>/dashboard`, user `admin`. It shows, in near real time:

- **general statistics**: connected devices, security alerts, network I/O, flows, contacted domains
- a **world map** of the servers contacted: spot the country you did not expect
- **network flows**: application, category, domain, destination, country, volume
- **security alerts** raised by Suricata

It is the first place to look. Ask yourself: does this device talk more than it should? To whom? When?

⚠ The PiRogue keeps **5 days** of history. Export what you need, or send it to Colander.

Live demo, part 2

Reading the dashboard: something is wrong

What we observe on the journalist's phone

Observation	Value
DNS query, repeated	<code>sync.update-wire.<lab domain></code>
Destination	the lab C2 server: a hosting provider, not Wire's infrastructure
Pattern	TLS flow every ~60 s, small payloads, day and night
Port	8443, uncommon for consumer apps
Suricata	<code>PTS-LAB LAB-001 C2 domain lookup</code> and <code>... C2 TLS SNI</code>

One of these alone proves little. Together, they draw a picture.

Suricata alerts: interpretation

Each alert contains:

- a **signature**: what pattern was matched, e.g. `ET MOBILE_MALWARE` rules for known spyware families
- a **severity**: how bad the rule author thinks it is
- **source and destination**: who talked to whom, with ports
- a **timestamp**

An alert is a lead, not a verdict. Rules fire on ad networks, misconfigured apps and real spyware alike. The signature name tells you *what to go read about*.

Suricata alerts: triage

For each alert, ask:

1. Which device triggered it?
2. Is the remote server known? Look it up: Threatr, passive DNS, WHOIS.
3. Does it repeat? **Beaconing patterns matter more than one-offs.**
4. Does it correlate with other alerts or unusual flows from the same device?
5. Does the timing match the intake report? Our journalist's SMS arrived weeks ago; when did this traffic start?

Triage outcome: **false positive, needs investigation, or indicator of compromise.**

Network DPI classification

NFStream classifies each flow:

- application protocol (TLS, DNS, QUIC...)
- application name when identifiable (WhatsApp, Telegram, Google services...)
- volume in both directions, duration, timing

What to look for:

- **unknown** applications where everything else is labeled
- unexpected destinations for known apps
- traffic when the device should be idle
- upload volume larger than download: a phone that *sends* a lot is exfiltrating something

Question

A device shows a flow to an IP in a country where the user knows nobody, every 5 minutes, small and regular payloads, at all hours, on port 8443.

What does this pattern suggest?

What would you check next, and in what order?

From PiRogue to Colander

With a **device monitoring** in a case, the PiRogue does not keep its data to itself:

- **network flows and Suricata alerts are sent into the case** by Mongoose
- alerts are linked to their flow through the **Community ID**
- each flow gets a **risk**: normal, suspicious or critical, from its alerts
- flow details: duration, direction, server name, **geolocation**
- look up any IP in **Threatr**, and **import a flow into the case** as entities

Capture happens on the PiRogue. Investigation happens in Colander.

Live demo, part 3

Confirming the threat in Colander

Identifying IOCs in network traffic

Indicators of compromise found in traffic:

- **domains:** C2 servers, exfiltration endpoints
- **IP addresses:** infrastructure of the operator
- **URLs:** payload delivery, phishing pages, like our journalist's SMS link
- **certificates:** TLS certificates reused across campaigns
- **behavior:** beaconing intervals, volumes, protocols

Cross-check against public threat intelligence before drawing conclusions. An IP shared by thousands of sites (CDN, cloud) is a weak indicator on its own.

Before you look it up: TLP and PAP

Querying a domain on a public service **tells the world you are interested in it**, and sometimes tells the operator.

	TLP: who may <i>receive</i> it	PAP: what you may <i>do</i> with it
RED	named people only	passive only, nothing on the network
AMBER	need-to-know organizations	online checks allowed (e.g. VirusTotal)
GREEN	a trusted community	active actions (ping, block...)
CLEAR	anyone	no restriction

Set TLP and PAP on every entity in Colander. Module 3: feeds use the TLP to decide what gets shared.

Extracting and documenting IOCs for reporting

For every IOC, record in Colander:

- the observable itself (domain, IP, URL, hash)
- **where it was seen:** device, capture, timestamp
- **why it is suspicious:** alert, DPI anomaly, threat intel match, beaconing
- the **supporting evidence:** PCAP reference and hash, imported flow, screenshot
- its **TLP and PAP**

Write it so that a colleague who was not in the room can follow the reasoning. Well-documented IOCs are what turn a capture into a report someone can act on. Module 3 covers how to share them.

Exercise

Using the PiRogue and the simulated malicious device:

1. connect the device and capture its traffic
2. identify at least one suspicious flow on the dashboard
3. triage the related Suricata alerts: false positive, investigate, or IOC?
4. decide the PAP, then query Threatr on the destination if allowed
5. import the flow into your Colander case
6. document the IOC with its full context, TLP and PAP

Work in pairs. 20 minutes, then we compare findings.

Case LAB-001: status after today

-  device traffic captured, PCAP hashed and preserved
-  beaconing to `sync.update-wire.<lab domain>` identified and triaged
-  flow imported into the case, observables created with TLP/PAP
-  what is the implant itself? Which app? (module 3: MVT, artifacts, Mandolin)
-  who else should know? (module 3: sharing, feeds, MISP)

Questions & resources

- Guide, capture and analyze a device's traffic: [🔗 docs.pts-project.org/guides/capture-and-analyze-traffic](https://docs.pts-project.org/guides/capture-and-analyze-traffic)
- Guide, handle a potentially compromised device: [🔗 docs.pts-project.org/guides/handle-a-compromised-device](https://docs.pts-project.org/guides/handle-a-compromised-device)
- Guide, handle a potentially malicious app: [🔗 docs.pts-project.org/guides/handle-a-malicious-app](https://docs.pts-project.org/guides/handle-a-malicious-app)
- Documentation: [🔗 docs.pts-project.org](https://docs.pts-project.org)
- Community Discord: [🔗 discord.gg/qGX73GYNdp](https://discord.gg/qGX73GYNdp)

Next module: **PTS ecosystem, Colander, integrations.** We finish the investigation.